



aLinha – a CISOaaS

Advisors:

- João Almeida (joao.rafael.almeida@ua.pt)
- Daniel Ferreira (danielmartinsferreira@ua.pt)

Collaborators:

- Sebastião Teixeira (sebastiao.teixeira@ua.pt)
- Vicente Barros (vmabarro@ua.pt)

1. Background

Small and medium-sized enterprises face the same regulatory and threat exposure as large organisations, but rarely have a security officer, a security budget, or the expertise to interpret obligations such as the NIS2 Directive and its Portuguese transposition, the GDPR, and, increasingly, the EU AI Act. Compliance today is handled through scattered spreadsheets, generic templates, and occasional consultancy, which makes it costly, hard to sustain, and difficult to evidence to authorities, auditors, or customers. aLinha proposes a CISO-as-a-Service (CISOaaS) platform: a unified, AI-assisted service that gives resource-constrained organisations the governance, monitoring, and reporting functions of a security officer, while keeping accountability with the organisation's own designated responsible person and with certified humans who validate every client-facing output.

2. Goals

- Develop a functional prototype of a CISOaaS platform adapted to the compliance workflows of Portuguese SMEs.
- Centralise core processes such as maturity and gap assessment, policy and evidence management, and incident reporting.
- Reduce the manual effort of compliance through an AI layer that drafts, prioritises, and explains, with human review before anything is issued.
- Ensure data security, transparency, and auditability of all assessments and generated documents.
- Provide a scalable foundation for future iterations, with potential to integrate technical monitoring sources and additional regulatory frameworks.

3. Main Functionalities

- Client & Entity Management: registration of client organisations, their sector, size, regulatory scope, and designated responsible person.
- Maturity & Gap Assessment: guided questionnaire staged against SOC-CMM tiers, producing a current-tier result, the applicable target tier, and a prioritised remediation roadmap.
- Policy & Evidence Management: generation of policies and procedures from assessment results, and collection and tracking of evidence per obligation (NIS2 Art. 21 measures, GDPR, AI Act).



- Incident Reporting Support: workflow and drafting assistance for the 24-hour, 72-hour, and one-month NIS2 notification cadence.
- Dashboard & Indicators: quick visualisation of key metrics (compliance coverage, open gaps, evidence status, upcoming deadlines) for both the service provider and the client.

4. Work plan

Phase 1 – Requirements & Planning (October)

- Identify SME compliance needs through interviews with target organisations and analysis of the applicable regulation.
- Define platform scope, MVP priorities, and user requirements for the two user types (provider and client).
- Set up development workflow, tools, and responsibilities.

Phase 2 – System Design (Early November)

- Design system architecture (backend, frontend, database, AI service boundary).
- Define roles, permissions, and multi-tenant data isolation.
- Draft wireframes and UI mockups for the assessment flow and dashboard.

Phase 3 – MVP Implementation (Mid November – December)

- Develop the core platform and integrate the maturity & gap assessment module.
- Deliver MVP in December for initial evaluation.

Phase 4 – Extended Implementation (January – March)

- Expand with policy generation, evidence management, and incident reporting support.
- Integrate the AI layer with human-review checkpoints; improve integration, usability, and performance.

Phase 5 – Testing & Validation (April)

- Perform thorough unit, integration, and acceptance testing.
- Conduct user testing sessions with pilot SMEs.
- Apply improvements based on feedback.

Phase 6 – Deployment & Documentation (May)

- Deploy prototype in a controlled environment.
- Deliver user documentation and training materials.
- Present final system and recommendations for future iterations.